

Table of Contents

Cisco Secure Workload — HIPAA Compliance Framework

Reference Design | Healthcare Accounts

Version: 1.0

Use Case: Fresh Install, Hybrid Environment (On-Prem + Cloud)

Reader's Guide

Who this is for. Covered entities and business associates handling electronic Protected Health Information (ePHI), and the security teams preparing for an OCR review or proactive HIPAA risk analysis.

Questions this reference design helps you answer:

- *Can I prove ePHI workloads are isolated from non-ePHI systems and that the boundary hasn't drifted since the last attestation? (§164.312(a)(1), §164.308(a)(1)(ii)(B))*
- *When a clinical or billing application is patched, can I show what network conversations changed as a result? (§164.308(a)(1)(ii)(D))*
- *If an OCR investigator asks for ePHI access logs over a specific window, what artifact do I hand over? (§164.312(b))*
- *If a clinician's workstation is compromised, can I demonstrate that lateral movement to ePHI systems was structurally prevented, not just that it didn't happen to occur? (§164.308(a)(6), §164.312(a)(1))*
- *Are my Business Associate Agreements backed by an actual technical boundary, or by trust alone? (§164.314(a))*

What you'll need. A current ePHI system inventory, your most recent §164.308(a)(1)(ii)(A) risk analysis, and either CSW already deployed or scope decisions for a planned deployment.

Where to start. Sections 1–4 if you're scoping; 5–7 if you're ready to design policy; 9–10 if you're preparing for an audit within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro) · [Epic EHR microsegmentation guide](#) (step-by-step Epic tier rollout)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow	Run ADM ≥2 weeks; export	Days 11–28

Phase	Goal	Key CSW actions	Typical duration
	map	clusters; app-owner signoff	
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Continuous ePHI boundary proof via scope + enforce — not just BAA paperwork
- Process-level flow telemetry answers OCR 'who accessed what' faster than SIEM alone
- ADM replaces stale PHI network diagrams with behaviour-derived maps

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

This reference design guides deployment of Cisco Secure Workload (CSW) in healthcare environments to support technical and operational evidence for elements of the HIPAA Security Rule commonly mapped to workload segmentation, logging, and risk-analysis inputs. CSW provides workload-level visibility, micro-segmentation, vulnerability exposure context, and forensic telemetry — all subject to deployment scope and complementary administrative, physical, and organizational controls.

HIPAA Security Rule Structure

Safeguard Category	Relevant CSW Capabilities
Administrative Safeguards (§164.308)	Policy enforcement evidence, audit-control inputs, risk-analysis data
Physical Safeguards (§164.310)	Limited / out of scope; CSW can only provide logical workload-boundary evidence that may support facility or device-control narratives
Technical Safeguards (§164.312)	Micro-segmentation, plaintext-flow detection / blocking, audit logs, identity-aware access evidence where integrated
Organizational Requirements (§164.314)	BAA scope definition, third-party access control

2. Pre-Deployment Checklist

Before deploying CSW sensors, confirm the following:

- ☐ CSW cluster (SaaS or on-prem) is provisioned and accessible
- ☐ Network connectivity from workloads to CSW cluster (port 443 outbound)
- ☐ Linux/Windows agent compatibility verified for all target workloads
- ☐ Cloud provider accounts connected (AWS, Azure, GCP) via CSW cloud connectors

- ❑ Stakeholders identified: CISO, Compliance Officer, Infrastructure Lead
 - ❑ Change management window approved for sensor installation
-

3. Phase 1 — Sensor Deployment (Days 1–5)

3.1 On-Premises Workloads

Install Software Sensors:

```
# Linux (RHEL/CentOS/Ubuntu)
rpm -ivh tet-sensor-<version>.rpm      # RHEL/CentOS
dpkg -i tet-sensor-<version>.deb        # Ubuntu/Debian
```

```
# Verify sensor is running
systemctl status csw-agent
```

Key Sensor Configuration:

- Enforcement Mode: **Monitoring Only** (do NOT enforce at this stage)
- Data Collection: Enable process hash, network flow, and vulnerability exposure visibility where supported
- Tags: Apply env:production, compliance:hipaa, data:phi from Day 1

3.2 Cloud Workloads (AWS / Azure / GCP)

Option A — Software Sensor on Cloud VMs: Same as on-prem install above.

Option B — CSW Cloud Connectors (agentless):

```
CSW UI → Platform → External Orchestrators
→ Add AWS/Azure/GCP connector
→ Provide IAM Role (AWS) or Service Principal (Azure)
→ Enable VPC Flow Log ingestion
```

Cloud connector provides:

- Instance inventory auto-discovery
- VPC/VNET flow telemetry
- Security Group / NSG mapping
- Tag-based scope inheritance

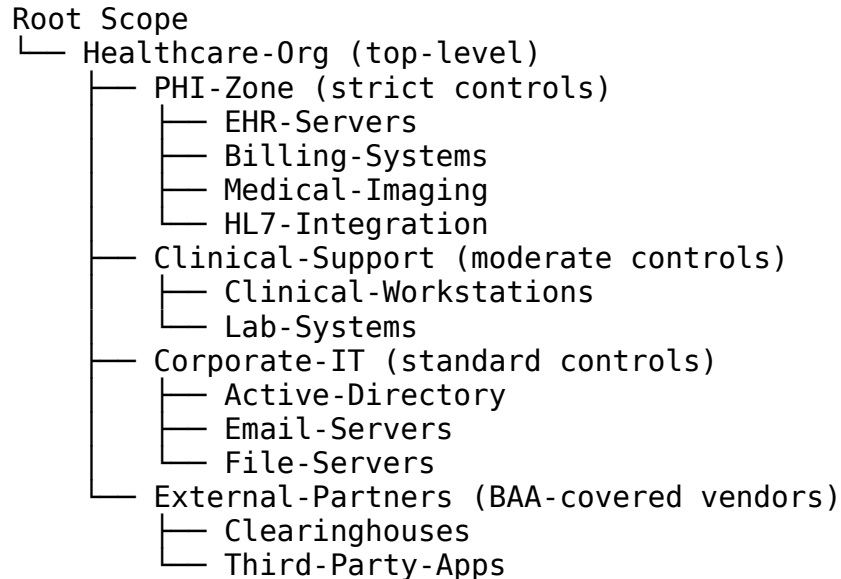
3.3 Sensor Validation

```
CSW UI → Manage → Agents
→ Confirm all sensors show "Active" status
→ Verify telemetry flowing (green flow indicators)
→ Check agent version alignment
```

4. Phase 2 — Scope & Inventory Design (Days 6–10)

4.1 HIPAA Scope Architecture

Design scopes around PHI data classification. Recommended hierarchy:



4.2 Inventory Filters for ePHI Discovery

Create filters to auto-populate scopes before apps are formally identified:

Filter: PHI-Zone-Candidates

- Process contains: "epic", "cerner", "meditech", "allscripts"
- Port listened: 1521 (Oracle), 5432 (Postgres), 1433 (MSSQL)
- Tag: data=phi (if pre-tagged in cloud)
- Hostname contains: "ehr", "emr", "pacs", "hl7"

Filter: High-Value-Databases

- Process: mysqld, postgres, oracle, sqlserver
- Listening on: 3306, 5432, 1521, 1433

4.3 Labeling Strategy

Apply consistent labels across all workloads:

Label Key	Example Values	Purpose
env	production, staging, dev	Environment segregation
compliance	hipaa, pci, none	Regulatory scope
data	phi, sensitive, public	Data classification
app	epic, cerner, custom-ehr	Application identity
owner	clinical-ops, it-ops	Team accountability

5. Phase 3 — Application Dependency Mapping (Days 11–21)

5.1 ADM Configuration

ADM reveals actual communication patterns — critical for HIPAA access controls.

CSW UI → Investigate → Application Dependency Mapping

- New Workspace
- Name: "Healthcare-HIPAA-ADM"
- Select Scope: Healthcare-Org (or PHI-Zone)
- Time Window: 2–4 weeks (capture business cycles)
- Start ADM

ADM Collection Settings:

- Enable **process context** (shows which process opened each connection)
- Enable **user context** if OS sensors support it
- Set retention: minimum 30 days for HIPAA audit trail

5.2 ADM Analysis for HIPAA

During ADM review, document the following for each application cluster:

Question	HIPAA Relevance
Which workloads receive connections from outside PHI-Zone?	Unauthorized access risk (§164.312(a))
Are database connections encrypted (port 5432 vs 5432-SSL)?	Encryption in transit (§164.312(e))
Which systems access EHR servers?	Minimum necessary access (§164.312(a)(2)(ii))
Are there unexpected lateral connections within PHI-Zone?	Audit control gap (§164.312(b))
Which external IPs/FQDNs do PHI workloads reach?	Business Associate identification (§164.314)

5.3 ePHI App Identification Workflow

Since apps are not yet identified, use ADM output to classify:

1. **Export ADM clusters** → review process names + ports
 2. **Interview app owners** → confirm which clusters handle PHI
 3. **Tag confirmed PHI apps** in CSW inventory
 4. **Move tagged workloads** into PHI-Zone scope
 5. **Re-run ADM** scoped to PHI-Zone only for policy generation
-

6. Phase 4 — Policy Development (Days 22–35)

6.1 HIPAA-Aligned Policy Framework

Translate HIPAA controls into CSW policy constructs:

Absolute Policies (Always Enforced):

DENY: Any → PHI-Zone (default deny inbound)
DENY: PHI-Zone → Internet (no direct internet from PHI workloads)
DENY: Corporate-IT → PHI-Zone (IT admin traffic blocked except jump hosts)

Allowlist Policies (Least Privilege):

ALLOW: EHR-Servers ↔ Billing-Systems (port 443, 8443)
ALLOW: Clinical-Workstations → EHR-Servers (port 443)
ALLOW: HL7-Integration → EHR-Servers (port 2575 HL7 MLLP)
ALLOW: EHR-Servers → Active-Directory (port 389, 636 LDAP/LDAPS – LDAPS only for HIPAA)
ALLOW: Jump-Host → PHI-Zone (port 22, 3389 for admin)
ALLOW: PHI-Zone → Monitoring-Stack (port 443 outbound to CSW cluster)

Catch-All (Audit Everything Else):

LOG: Any → PHI-Zone (unmatched flows – triggers alert)
LOG: PHI-Zone → Any (unmatched outbound)

6.2 Policy Workspace Setup

CSW UI → Defend → Segmentation
→ New Workspace
→ Name: "HIPAA-PHI-Zone-Enforcement"
→ Scope: PHI-Zone
→ Import ADM policies (auto-generated baseline)
→ Review and refine
→ Set mode: Simulation first → then Enforcement

6.3 Enforcement Progression

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate no false positives
2	Enforcement (low priority rules)	1 week	Enforce clear blocks
3	Full Enforcement	Ongoing	Production HIPAA posture

7. Phase 5 — HIPAA Control Mapping

7.1 Technical Safeguards (§164.312)

HIPAA Control	Control ID	CSW Implementation
Unique User Identification	§164.312(a)(2)(i)	Process-user context in ADM; alert on shared credentials via anomaly detection
Emergency Access Procedure	§164.312(a)(2)(ii)	Break-glass policy workspace; alert-only mode for emergency IPs
Automatic Logoff	§164.312(a)(2)(iii)	Enforce session policies via network controls; short-lived allow rules
Encryption & Decryption	§164.312(a)(2)(iv)	CSW identifies unencrypted PHI flows (HTTP vs HTTPS, LDAP vs LDAPS)
Audit Controls	§164.312(b)	Full flow telemetry retained; process-level audit trail
Integrity Controls	§164.312(c)	Policy violation alerts; workload hash verification
Authentication	§164.312(d)	Enforce LDAPS/Kerberos paths; block unauthenticated DB access
Encryption in Transit	§164.312(e)(2)(ii)	Detect and block unencrypted PHI flows; enforce TLS-only paths

7.2 Administrative Safeguards (§164.308)

HIPAA Control	Control ID	CSW Implementation
Risk Analysis	§164.308(a)(1)	Vulnerability detection reports; CVE mapping to PHI workloads
Workforce Access Management	§164.308(a)(3)	Scope-based policy enforcement; access logs per workload
Security Incident Procedures	§164.308(a)(6)	Forensic telemetry for incident reconstruction; anomaly alerts

HIPAA Control	Control ID	CSW Implementation
Contingency Plan	§164.308(a)(7)	Policy export/backup; DR policy workspace
Evaluation	§164.308(a)(8)	Compliance dashboard; drift detection alerts

8. Phase 6 — Vulnerability & Risk Management

8.1 Vulnerability Detection

CSW UI → Investigate → Vulnerability Report

- Scope: PHI-Zone
- Filter: CVSS Score ≥ 7.0
- Export for compliance evidence

HIPAA Relevance: §164.308(a)(1) requires ongoing risk analysis. CSW vulnerability data can inform that analysis with workload-level CVE mapping, but it remains one input among threat, impact, control-testing, BAA, and operational-risk evidence.

8.2 Prioritization for PHI Workloads

Priority 1: Critical CVEs (CVSS 9.0+) on EHR/Billing servers → Patch within 24 hours

Priority 2: High CVEs (CVSS 7.0–8.9) on PHI-Zone → Patch within 7 days

Priority 3: Medium CVEs on Clinical-Support → Patch within 30 days

8.3 Compensating Controls via CSW

When patching is delayed, implement compensating controls in CSW:

- Restrict vulnerable port to approved source IPs only
- Add anomaly detection alert for the vulnerable process
- Log all connections to affected workload for manual review

9. Phase 7 — Monitoring & Alerting

9.1 HIPAA-Required Alerts

Configure the following alerts in CSW:

Alert	Trigger	HIPAA Control
Unauthorized PHI Access	Any unapproved source → PHI-Zone	§164.312(a)
Unencrypted PHI Flow	HTTP/FTP detected from PHI-Zone	§164.312(e)
Lateral Movement	New east-west flow	§164.308(a)(6)

Alert	Trigger	HIPAA Control
	within PHI-Zone	
External Exfiltration	PHI-Zone → Unknown external IP	§164.312(e)
Policy Violation	Enforced policy block triggered	§164.308(a)(6)
Vulnerability Spike	New Critical CVE on PHI workload	§164.308(a)(1)
Sensor Offline	Agent stops reporting	§164.312(b)

9.2 Forensic Telemetry for Incident Response

CSW retains full network + process telemetry. For HIPAA breach investigation:

CSW UI → Investigate → Flow Search

- Time range: incident window
- Source/Destination: affected workload
- Export: full flow log with process context

CSW UI → Investigate → Process Search

- Filter: PHI workload + time range
- Identify anomalous processes + parent-child relationships

Retain forensic exports for minimum **6 years** per HIPAA documentation requirements.

10. Reporting & Evidence Collection

10.1 Evidence per Audit Cycle (Quarterly Recommended)

Evidence Item	CSW Source	HIPAA Control
Policy enforcement log	Defend → Policy Analysis	§164.312(a)
Vulnerability exposure report	Investigate → Vulnerability	§164.308(a)(1)
Flow audit log (PHI-Zone)	Investigate → Flow Search	§164.312(b)
Policy violation report	Alerts → Triggered Events	§164.308(a)(6)
Scope membership snapshot	Inventory → Export	§164.308(a)(3)
Encryption compliance	Flow analysis (protocol filter)	§164.312(e)

10.2 Ongoing Compliance Posture

- Schedule **monthly** scope/inventory reviews — workloads join/leave PHI-Zone
 - Schedule **quarterly** policy workspace reviews — validate rules still reflect ADM
 - Track **policy drift** — compare current policy to baseline export
 - Maintain **ADM re-runs** every 90 days to detect new application dependencies
-

11. Common Pitfalls

Pitfall	Mitigation
PHI workload not in correct scope	Run ADM with labels; review scope membership weekly
Encryption detected but on wrong port	Validate TLS termination points; don't assume SSL by port number
Cloud workloads missing from inventory	Verify cloud connector permissions (read access to EC2/VMs)
Policy too broad (subnet-level instead of workload)	Use workload identity (OS fingerprint, process hash) not just IP
ADM run too short	Always run minimum 2 weeks; include month-end processing cycles
Enforcement breaks a clinical application	Always run simulation mode first; stage rollout by scope

Related Frameworks

- [CSW Epic EHR Microsegmentation Guide](#) — step-by-step Epic tier scopes, ADM, Interconnect/HL7, enforcement, and quarterly HIPAA evidence pack (implements many controls below for Epic estates).
 - [NIST SP 800-53 Rev 5](#) — HHS recognises 800-53 as a basis for satisfying §164.306(a) administrative, physical, and technical safeguards.
 - [ISO/IEC 27001:2022](#) — for healthcare entities operating under both HIPAA and ISO 27001.
 - [NIS2 \(EU 2022/2555\)](#) — for healthcare entities with EU operations; healthcare is an essential sector under NIS2.
 - [NIST SP 800-207](#) — the ZTA pattern that underpins many of the technical safeguards above.
-

Document prepared for Cisco healthcare account engagements. Replace [Customer Name] and bracketed fields before customer delivery.